

Fantavega Re-audit: Security, Performance and Ghost Sessions

Audit date: 9 August 2026

Reviewed revision: 31829a7dd12f69ff57822f1c67c41447e3ac21f8

Repository: <https://github.com/nuno80/fantavega>

Executive verdict

The authorization fix for `user/auction-states`, league-scoped auction processing, cooldown batching, and per-user/per-league toggles are correctly present.

The timer change is not correct as merged. It reintroduces the legacy `activateTimersForUser` calls that PR #38 deliberately removed, while the repository already contains a scoped, atomic `response-timer/viewed` endpoint. Any poll of either auction-state endpoint currently starts every pending timer for that user, including timers from another league. This contradicts the invariant that a timer starts only after the relevant raise is visible.

Three corrective PRs are recommended. The attached patch appliers are fail-closed: `--check` verifies the expected source fragments without writing, and a normal run applies the changes.

Finding summary

Severity	Finding	Impact	Corrective PR
High	Legacy timer activation was reintroduced in both polling routes	Polling/reconnect or opening League A can start unseen timers in League B	PR A
High	Cooldown writes use <code>INSERT OR REPLACE</code> on the shared preference row	Applying a cooldown silently resets favorites, starter flags, integrity and FMV preferences	PR B
High	Three admin server actions check authentication but not admin role	A signed-in caller can mutate team names, league status or active roles	PR C
Medium	Historical preference migration lacks <code>preference_type</code> and <code>expires_at</code>	Existing databases can pass <code>CREATE TABLE IF NOT EXISTS</code> yet fail at runtime	PR B
Medium	Viewed confirmation currently occurs only when the action modal opens	A rendered response card can remain untimed until the user clicks Abandon	PR A
Medium	Toggle API accepts weakly validated IDs and values	Invalid values can be persisted; <code>parseInt</code> accepts strings such as <code>7junk</code>	Follow-up
Medium	Scheduler lease has no renewal	A task exceeding 45 seconds can overlap on another instance	Follow-up
Low	Global cooldown batching without <code>leagueId</code> collapses rows by <code>player_id</code>	Result depends on row order across multiple leagues	Follow-up

Ghost-session and timer analysis

Robust parts

Socket disconnect handling tracks every socket for a user, waits ten seconds, cancels stale logout callbacks after reconnect, and closes a session only when its persisted heartbeat is not newer than the disconnect. The unique active-session index protects concurrent heartbeat upserts. Timer activation through `activateResponseTimerForViewedAuction` is a compare-and-set operation scoped by user, league, auction and active auction status.

Confirmed regression

Both `src/app/api/user/auction-states/route.ts` and `src/app/api/leagues/[league-id]/auction-state/route.ts` call `activateTimersForUser(user.id, heartbeatAt)`. That service queries pending timers by user only, not by the league being viewed, and activates all of them. The repository's own `scripts/assert-no-legacy-timer-activation.mjs` rejects these call sites, and `docs/PR/PR-remove-legacy-timer-activation.md` says they must not exist.

The supplied implementation note is internally inconsistent: it says presence must not activate timers, but the implementation activates timers immediately after presence is persisted. PR A restores the viewed-only invariant and makes the mounted response-needed state call the scoped endpoint.

Network edge cases after PR A

A short reconnect does not activate a timer. HTTP heartbeat keeps presence alive without changing timer state. A temporary socket interruption is handled by the ten-second grace window. A partition longer than 120 seconds intentionally makes the session stale; this is a business threshold, not proof that the browser closed. Multi-instance socket maps remain local, but conditional DB heartbeat/logout prevents stale callbacks from overriding newer HTTP activity.

Security review

No direct SQL injection was confirmed in the reviewed hot paths. Dynamic preference columns come from a fixed server-side whitelist. Clerk authentication and league-access checks are present on the reviewed API routes.

The remaining high authorization issue is in server actions. `updateTeamNameAction`, `updateLeagueStatusAction`, and `updateActiveRolesAction` authenticate the caller but do not call `checkIsAdmin`; one writes directly to the database and the others call services without a caller role parameter. UI or route middleware is not a security boundary for a server action. PR C adds the same fail-closed role check used by safer actions in that file.

Preference and cooldown integrity

`user_player_preferences` stores personal toggles and cooldown metadata in one row keyed by `(user_id, player_id, league_id)`. Three cooldown paths use `INSERT OR REPLACE`. In SQLite, `REPLACE` deletes the old row and inserts a new one, so omitted toggle columns revert to defaults. PR B changes these writes to `INSERT ... ON CONFLICT DO UPDATE`, updating only cooldown fields.

The canonical schema includes `preference_type` and `expires_at`, but `database/migrations/add_user_player_preferences.sql` does not. Applying the canonical schema with `CREATE TABLE IF`

NOT EXISTS does not alter an existing table. PR B adds a guarded PRAGMA table_info compatibility repair during schema application.

Performance review

The cooldown N+1 was removed correctly: /api/players now performs one bulk lookup. The league-scoped expiry processor passes the URL league ID into processExpiredAuctionsAndAssignPlayers, preserving participant access without global side effects. The 1000-player cap is compatible with CallPlayerInterface, though pagination would still be healthier long-term.

Residual scaling work: renew the 45-second scheduler lease, replace instance-local rate limiting before horizontal scaling, and batch league-deletion queries to avoid SQLite parameter limits with very large auction histories.

CI status

At audit time, the database workflow for 31829a7 was green. The application-quality workflow had passed installation and TypeScript and was still executing tests, so the commit was not yet fully green. The no-legacy guard is expected to reject the two reintroduced call sites until PR A is applied.

Corrective PRs

PR A: fix(auction): restore viewed-only response timer activation

Removes activateTimersForUser from both polling routes. Heartbeats remain awaited. The current user's mounted response-needed state calls the existing scoped and idempotent response-timer/viewed endpoint.

PR B: fix(preferences): preserve personal flags when applying cooldowns

Replaces all three destructive cooldown REPLACE statements with conflict updates limited to cooldown fields. Repairs missing cooldown columns on existing preference tables.

PR C: fix(authz): enforce admin role inside league server actions

Adds server-side admin checks to team-name changes, league-status changes and active-role changes.

Applying and validating

Create one branch per patch from current main:

```
git checkout main
git pull --ff-only
git checkout -b fix/viewed-only-timer
python 0001-fix-viewed-only-timer-activation.patch.py --check
python 0001-fix-viewed-only-timer-activation.patch.py

node scripts/assert-no-legacy-timer-activation.mjs
```

```
pnpm type-check
pnpm test:run
pnpm test:e2e
pnpm build
```

Repeat from fresh `main` for patches 0002 and 0003. Add regression tests before merge: cross-league polling must not activate a timer, mounted response state must claim exactly once, cooldown must retain every personal toggle, and a non-admin invocation of each hardened action must fail without a database write.